2.0 Joomla! Découverte et Enumération :

Bien que sa part de marché soit moindre, Joomla est un System de Gestion de Contenu, utilisé pour des millions de sites web à travers le monde
Pour identifier "l'existence" de Joomla on peu inspecter le code source de l'applicat web ou examiner les fichiers et repertoires spécifiques - /robots.txt /administra /components/ /plugins/ pour identifier la version on a aussi souvent administrat manifests/files/joomla.xml
Il n'y à pas de mot de pass par défault mais le compt administrateur par défaul est admin...
Il existe des outils automatisés de reconnaissance comme droopescan accessible ici

2.1 Attaquer Joomla :

Comme avec Word-Press, avec des identifiants administrateurs, on peu éd un fichier de template et y rajouter notre propre code amenant à une RCE
Il existe evidemment de nombreuses vulnérabilités CVE que ce soit dans les extentions ou plus rare le coeur de Joomla, a nous de bien enumérer, bien comp rendre la vulnérabilité et enfin l'exploiter... Ca sera galère mais après c'est fou aussi s'entrainer au "scripting" en C puisque j'ai choisi uniquement ce langage.

3.0 Drupal Découverte et Enumération :

Drupal est notre dernier CMS étudié il est très populaire et utilisé par d nombreux sites gouvernementales et entreprises du fortune 500
Pour l'identifier il y a des indicateurs courants, le "Powered by Drupal" en de page, la présence d'un fichier CHANGELOG.txt ou d'une structure d'url unique comme /node/<nodeid>
L'outil droopescan permet d'enumérer de manière automatisé la version de drup les plugins installés et url intéressantes (Ca reste un outil et son enumération est pas fiable à 100% ni possible dans tout les cas

3.1 Drupal Attacks :

Nous avons comme toujours le CVE publiques diverses a rechercher... Une foi connecter en administrateur à une instance il est un peu plus dur d'obtenir u RCE, on peu activer le module Filtre PHP qui permet d'executer directement du directement dans le contenu d'une page
On peu créé un module piège et le télécharger, pour le module backdoor il faut dissimuler un fichier shell.php et un fichier .htaccess (fichier de config qui permet d modifier le compartiment du serveur pour ce dossier spécifique et tout ces sous sur sans toucher a config general du serveur) permissif. Ensuite Extend → Install module et on upload le *.tar.gz modifié...
Parmi les CVE notons la serie Druppalgeddon faill permettant souvent d'exécuter de code sur le serveur distant.
NB: Un bon entrainement est Armageddon de Hack The Box.

4.0 Tomcat Découverte et Enumération :

Un serveur web open-source conçu pour héberger les applications web basés sur Java, telles que celles utilisant les scripts Java et les JavaServer Page (JSP).
Les serveurs tomcat peuvent être identifiés par leur page d'erreur HTTP 404 unique qui peux également divulguer le numéro de version. La page /docs est un autre endr courant pour trouver des informations sur la version.
web.xml (descripteur de déploiement) Un fichier de configuration crucial situé dans le répertoire WEB-INF/ d'une application. Il définit comment les chemins d'url s mappés aux classes de servlets Java qui traitent les requêtes, ce fichier est une cible pour trouver une potentielle LFI